

BitLocker

środa, 11 czerwca 2025 21:31

Bitlocker polega na pełnodyskowym szyfrowaniu przy użyciu algorytmu AES z kluczem 128 lub 256 bitów

Zwykle w trybie XTS-AES

Kluczowe elementy

FVEK (Full Volume Encryption Key) - klucz służący bezpośrednio do szyfrowania danych na dysku

VMK (Volume Master Key) - klucz, którym szyfrowany jest FVEK. Jest to centralny element BitLockera

TPM (Trusted Platform Module) - sprzętowy moduł bezpieczeństwa przechowujący VMK lub jego część i weryfikujący integralność systemu przy starcie.

Proces:

1. Dane użytkownika są szyfrowane za pomocą FVEK
2. FVEK jest zaszyfrowany przez VMK
3. VMK może być chroniony:
 - Przez TPM
 - Hasło startowe, klucz USB, PIN lub ich kombinację
4. Przy starcie BitLocker odszyfrowuje VMK (np. za pomocą TPM), następnie FVEK i w końcu umożliwia dostęp do danych.

Tryb XTS-AES:

- Zabezpiecza przed atakami modyfikującymi zawartość dysku (np. Manipulacja sektorami)
- Ulepszony względem starszego trybu CBC (Cipher Block Chaining), który był używany w starszych wersjach

Główne cele:

- Ochrona danych w przypadku fizycznej utraty komputera
- Zapewnienie integralności systemu rozruchowego

Klucz odzyskiwania dostępu można zapisać do PDFa

Metody zabezpieczenia dysku bez systemu:

Hasło

Karta inteligenta

Przypisanie komputera jako zaufany dla dysku, tak że dysk będzie odszyfrowywał się automatycznie

Metody zapisywania kopii zapasowej:

Konto Microsoft

Dysk Flash usb

Zapisz w Pliku

Drukuj Klucz odzyskiwania

Jeżeli nie zapiszemy sobie żadnej z tych opcji jedyna opcja na odblokowanie dysku będzie reset danych co usunie wszystkie nasze dane

Jeżeli zapiszemy recovery key na koncie Microsoft będziemy mogli sobie go w każdej chwili podejrzeć, możemy też go wygenerować z panelu sterowania jeśli dysk jest odblokowany

W recovery Key jest unikalny identyfikator dysku który powinien zgadzać się z identyfikatorem który widzimy

Jedyna opcja żeby zapisać Recovery Key na zaszyfrowanym dysku jest zapisanie go do PDF na pulpit

Nowy Tryb szyfrowania XTS-AES lepszy dla dysków stałych w komputerze, XTS-Tweak Cipher

Lub

Tryb zgodności który jest lepszy dla dysków wyjmowanych z komputera stosuje AES-CBC

W obu przypadkach 128 bitów

Klucz odzyskiwania to 48 cyfrowe hasło numeryczne podzielone myślnikami na 6 cyfrowe bloki

Dla dysków systemowych nie ma możliwości zapisania klucza na Flash USB

Zaszyfruj tylko użyte miejsce najlepsza opcja dla komputerów które posiadamy od nowości

Zaszyfruj cały dysk najlepsza opcja dla używanych komputerów

Zmian w ustawieniach szyfrowania można dokonać z poziomu gpedit.msc

Blokowanie plug and play robimy z poziomu edytora rejestru

Automatycznie odblokowujący się pendrive

manage-bde -autounlock -enable E:

Wylaczenie zapisu na niechronione dyski robimy z poziomu gpedit.msc
Algorytm szyfrowania zmieniamy w gpedit.msc

Klucze Recovery po zastosowanej zmianie nieulegna zmianie jeśli chodzi o ich strukture

Można informacje zweryfikowac

Dzięki

(Get-BitLockerVolume –MountPoint G:).KeyProtector

Lub

(Get-BitLockerVolume –MountPoint G:).EncryptionMethod

OpenPGP

sobota, 14 czerwca 2025 18:56

OpenPGP - (Pretty Good Privacy) - otwarty standard do podpisywania i szyfrowania danych. Pozwala na:

- Generowanie kluczy
- Podpisywanie wiadomości
- Szyfrowanie danych
- Szyfrowanie wiadomości
- Zarządzanie kluczami

Najpopularniejszą implementacją OpenPGP jest GPG czyli GNU Privacy Guard, co ważne implementacja ta nie zawsze musi być aktualna co do zmian obecnych w standardzie OpenPGP

Tożsamość PGP składa się z

Identyfikatora

E-maila (opcjonalnie)

Imienia i nazwiska (opcjonalnie)

Komentarz (opcjonalnie, przy opcji full)

^Przynajmniej jedna z powyższych opcji musi być działająca^

Generowanie kluczy:

Wyróżniamy trzy sposoby:

--generate-key – tryb uproszczony z minimalną liczbą pytań, automatycznie wybiera typ klucza RSA+RSA, rozmiar to zazwyczaj 3072 bity, pyta tylko o podstawowe dane, nie daje wyboru opcji np.

Zaawansowanych kluczy

--full-generate-key

Pozwala ręcznie wybrać typ klucza, rozmiar klucza, termin ważności, można pominąć adres email

--expert - pozwala na tworzenie nietypowych konfiguracji np.:

- Klucze podpisujące bez możliwości szyfrowania
- ECC, Ed25519 Brainpool itd..
- Klucze do uwierzytelniania np.. Dla SSH
- Klucze podrzędne z określonymi zdolnościami
- Możliwość wyboru certyfikującego i niecertyfikującego klucza

Np.. Generowanie:

gpg --full-generate-key

Następnie jesteśmy przekierowani aby zabezpieczyć nasz klucz hasłem

SC – podpis

E – szyfrowanie

Domyślny termin ważności klucza to 3 lata a obecnie domyślny algorytm to ECC

Aby wyeksportować klucz publiczny

Gpg --list-key – listuje klucze

Aby wyeksportować używamy --export

Dodajemy --armor aby wylistować klucz do ascii

I dodajemy identyfikator uid

Czyli:

Gpg --export --armor "<identyfikator>" > pub_key.asc

Dla prywatnego klucza będzie

```
gpg --armor --export-secret-keys "Franciszek Krzeszowski" > fk_privkey.asc
```

Wtedy musimy podać hasło

Aby zaimportować klucz z sieci musimy mieć fingerprint

Gpg --keyserver keyserver.pgp.com --recv-keys <fingerprint>

Aby zaimportować pobrany klucz publiczny należy użyć

Gpg --recv-keys <nazwa pliku z pobranym kluczem>

Gpg --fingerprint "<imie z nazwiskiem>"

Aby zaszyfrować plik

```
Gpg --output <nazwapliku>.gpg --encrypt --recipient "dane odbiorcy" <plik_do_szyfrowania.txt>
```

Pliki szyfrujemy kluczem publicznym a podpisujemy kluczem prywatnym

Podpis odseparowany

```
Gpg --output plik.txt.sig --detach-sign plik.txt
```

Podpis i szyfrowanie w jednej komendzie

```
gpg --output plik.zaszyfrowany.gpg --encrypt --sign --recipient "Odbiorca" plik.txt
```

Są trzy tryby podpisu

Detached sign (plik.txt + plik.txt.sig)

```
gpg --verify plik.txt.sig plik.txt
```

Cleartext sign (plik.txt.asc)

```
gpg --verify plik.txt.asc
```

Binary signed (plik.gpg, plik.gpg)

```
gpg --verify plik.gpg
```

GPG wyświetli coś w stylu:

```
gpg: Signature made ... using RSA key ID ABCD1234
```

```
gpg: Good signature from "Jan Kowalski <email@example.com>"
```

Jeśli podpis jest błędny lub uszkodzony:

```
gpg: BAD signature from ...
```

Aby zweryfikować podpis pliku podpisanego i zaszyfrowanego należy go najpierw odszyfrować

Wtedy używamy

```
gpg --decrypt nazwisko.imie.txt-3.gpg
```

I dostajemy z powrotem informacje o kluczu jakim zaszyfrowany i o podpisie

Aby zdeszyfrować plik do pliku

```
gpg --output nazwisko.imie-2.txt --decrypt nazwisko.imie.txt-4.gpg
```

Aby unieważnić podklucz

```
gpg --edit-key Franciszek Krzeszowski
```

Wyświetl listę podkluczy

List

Wybierz klucz

Key N – gdzie N to numer klucza

Następnie

Revkey i potwierdzić

Aby teraz dodać nowy podklucz

Komenda addkey

Dodanie nowego klucza zatwierdzić hasłem

Aby uruchomić edycję klucza w trybie eksperckim:

```
gpg --edit-key --expert Franciszek Krzeszowski
```

Aby dodać tożsamość do klucza należy użyć adduid

Aby usunąć tożsamość należy ją wybrać za pomocą komendy uid a następnie użyć revuid

Aby przedłużyć ważność klucza należy użyć expire i wybrać który klucz np.. expire sec

Długość klucza publicznego zwiększa się wraz z ilością podkluczy zawartych w kluczu i zależy też od długości tych podkluczy

Primary aby ustawić nową tożsamość jako domyślną

Dla swojej tożsamości możemy zaimportować tylko klucz prywatny

Keepass

poniedziałek, 9 czerwca 2025 22:46

KeePass przechowuje pliki baz z hasłami w formacie .kdbx

Tworzenie nowej bazy haseł

1. Przejdź do **File** → **New**.
2. Wybierz lokalizację, w której chcesz zapisać bazę haseł.
3. Wprowadź **Master Password** oraz **Repeat Password**.
 - Jeśli klikniesz ikonę **trzech kropek** obok pola Master Password, nie będziesz musiał wpisywać hasła dwa razy.
4. (Opcjonalnie) Kliknij **Show expert options**, aby wyświetlić dodatkowe ustawienia:
 - Możesz utworzyć lub załadować plik klucza (**key file** w formacie .keyx lub .key).
5. Kliknij **Next**.
6. Uzupełnij dane bazy:
 - Nazwa bazy haseł
 - Opis
 - Domyślna nazwa użytkownika
 - Domyślny kolor
7. (Opcjonalnie) Wydrukuj **Emergency Sheet** (arkusz awaryjny):
 - Zawiera on wszystkie informacje potrzebne do odzyskania dostępu do bazy haseł.
 - Wypełnij go **ręcznie długopisem**.
 - **Przechowuj arkusz w bezpiecznym miejscu.**

Tworzenie nowego wpisu do bazy haseł:

1. Z poziomu menu otwartej bazy wybierz opcję Add entry (Ctrl + i)
2. Wypełnij pola:
 - Tytuł
 - Ikonka
 - UserName
 - Password
 - RepeatPassword
 - Opcjonalnie URL żeby wypełniało nam hasła na stronach internetowych
 - Notatki
 - Opcjonalnie date wygasnięcia
3. Dodatkowo KeePass oferuje nam password generator gdzie możemy dostosować hasło do własnych potrzeb
4. Możemy generować hasła używając zbioru znaków, lub regexu lub własnego customowego algorytmu.
5. W zakładce properties możemy nadpisać ustawiony wcześniej URL dla konkretnych przeglądarek

Autouzupełnianie w przeglądarce

1. Pobierz KeePassRPC
2. Pobierz AddOn do swojej przeglądarki np. Kee
3. Połącz się z bazą haseł
4. Wpisz hasło i działa

WAŻNA ZALETA!
BRAK OGRANICZEŃ!

Wzorce menadżera haseł

a - litery małe od a do z oraz cyfry 0 do 9
A - litery od a do z oraz od A do Z oraz cyfry 0 do 9
U - litery od A do Z oraz cyfry 0 do 9
d - cyfry od 0 do 9
h - małe znaki hexowe czyli od 0 do 9 i od a do f
H - duże znaki hexowe czyli od 0 do 9 i od A do F
l - małe litery od a do z
L - mieszane litery od a do z i od A do Z
u - wielkie litery od A do Z
v - samogłoski małe aeiou
V - samogłoski mieszanie AEIOU aeiou
Z - samogłoski duże AEIOU
c - małe spółgłoski
C - duże i małe spółgłoski
z - duże spółgłoski
p - znaki punktowe ,,:;
b - nawiasy {}[]<>

Protokoły i algorytmy kryptograficzne wykorzystywane przez KeePass

- W celu zachowania poufności stosowane są AES, ChaCha20 (od wersji 2.x)

- Integralność to HMAC-SHA256 – stosowany do weryfikacji integralności nagłówka bazy danych, SHA-256 – do haszowania haseł i danych wejściowych

Metody zapewniania poufności i integralności danych w KeePass

Poufność:

- Dane są szyfrowane przy pomocy AES-256 lub ChaCha20
- Na klucz szyfrowania składa się hasło, key file, opcjonalnie dane z Windows User Account
- Mechanizmy KDF takie jak Aes-KDF czy Argon2 zabezpiecza przed atakami brute force

Integralność:

- Użycie HMAC-SHA256 zapewnia wykrycie manipulacji nagłówkiem bazy danych
- Dodatkowo baza danych kdbx jest plikiem binarnym, którego modyfikacja powoduje błąd odczytu

Dostępność:

Plik jest przechowywany offline

Brak zagrożenia wynikających z przechowywania haseł na serwerze

KeePass pozwala na eksport i kopie zapasowe

Brak możliwości odzyskania czynnika, na klucz składają się wszystkie wybrane czynniki uwierzytelniające

LUKS

piątek, 13 czerwca 2025 00:07

LUKS – Linux Unified Key Setup – odpowiednik bitlockera na Linuxy

Formatowanie:

Szybkie – nie nadpisuje istniejących danych

Wolne – nadpisuje istniejące dane zerami

Szyfrowanie LUKS obsługuje cryptsetup

Jak stworzyć partycję LUKS zaszyfrowaną imieniem i nazwiskiem

Urządzenie musi być unmounted

1. `sudo cryptsetup luksFormat /dev/sda1` (sformatuj na LUKS)
2. (wpisz YES z dużych liter)
3. (wpisz hasło)
4. (powtórz hasło) "FranciszekKrzyszowski"
5. `sudo cryptsetup open /dev/sda1 nazwa_partycji` (utwórz partycję)
6. (wpisz hasło)
7. `sudo mkfs.ext4 /dev/mapper/nazwa_partycji` (sformatuj na ext4)
8. `sudo mount /dev/mapper/ /mnt nazwa_partycji` (zamontuj partycję w mount)
9. `sudo umount /mnt` (wymontuj partycję)
10. `sudo cryptsetup close nazwa_partycji` (zamknij partycję)

Montowanie z GUI

1.Unlock partycja

2. zaznacz odblokowaną partycję filesystem

3. Kliknij trójkącik po lewej

Odmontowanie z GUI

1. Kliknij kwadracik po lewej (tam gdzie był wcześniej trójkąt)

Montowanie z terminala

1. `sudo cryptsetup open /dev/sda1 nazwa_partycji` (otwórz luks jako partycję o nazwie nazwa_partycji)
2. `Sudo mount /dev/mapper/nazwa_partycji /mnt` (zamontuj utworzoną partycję w /mnt)

Odmontowanie z terminala

1. `sudo umount /mnt` (odmontuj dysk z mnt)
2. `sudo cryptsetup close nazwa` (zamknij partycję)

Weryfikacja konfiguracji

1. `sudo cryptsetup luksDump /dev/sdb1`
2. Użyty algorytm szyfrowania to pole Cipher:, domyślnie aes-xts-plain64
3. Wielkość klucza to Cipher key: domyślnie 512 bits
- AES XTS używa dwóch kluczy 256 bitów
3. Funkcja wyprowadzania klucza Key Derivation Function: PBKDF: domyślnie argon2id
4. Konfiguracja wyprowadzania hasła
- Time cost (czasochłonność) : 4
- Memory: 396398 - ile pamięci RAM w KB
- Threads: 4 – Liczba wątków

PBKDF – password based key derivation function, funkcja która nasze hasło zamienia w silny klucz szyfrujący

Zmiana hasła:

1. `Sudo cryptsetup luksAddKey /dev/sdb1` (Dodaj nowe hasło)
2. (Wpisz jedno ze starych haseł)
3. (Wpisz i potwierdź nowe hasło)
4. `sudo cryptsetup luksRemoveKey /dev/sdb1`
5. (wpisz hasło które chcesz usunąć)

DOdawanie KeyFile jako metoda odblokowania

`Sudo cryptsetup luksAddKey /dev/sdb1 ~/keyfile/path`

2. (wpisz dowolne obecne hasło)

Odblokowywanie KeyFile'em

`Sudo cryptsetup open --key-file ~/keyfile/path /dev/sdb1 nazwa_partycji`

OTP+Auth

środa, 11 czerwca 2025 00:15

Odzyskiwanie dostępu:

1. Kody zapasowe, podczas pierwszej konfiguracji 2FA, wiele usług pozwala na generowanie kodu zapasowych
Można użyć ich zamiast authenticatora aby zalogować się i ponownie skonfigurować 2FA
Wymóg, musiałeś je wcześniej zapisać
2. Kopia zapasowa, np. Google authenticator pozwala zsynchronizować authenticator z kontem google
Authy oferuje synchronizację chmury i przywracanie kont po uwierzytelnieniu (numer telefonu + kopia zapasowa)
Microsoft authenticator umożliwia kopie zapasową konta w chmurze OneDrive
W tych opcjach wymagane jest wcześniejsze włączenie backupu
3. Ostatecznością jest kontakt z pomocą techniczną, i przykładowo weryfikacja tożsamości dowodem osobistym, mailem, lub wyciągiem z konta bankowego np. Amazon lub Binance
4. Eksportowanie konta na nowe urządzenie

Proton Pass

wtorek, 10 czerwca 2025 00:14

1. ProtonPass to nowoczesny menadżer haseł opracowany przez twórców ProtonMail. Jego funkcjonalności to:
 - Dostęp przez apki mobilne, przeglądarki
 - Przechowywanie haseł, loginów, notatek, aliasów email
 - Generowanie silnych haseł
 - Synchronizacja pomiędzy urządzeniami w czasie rzeczywistym
 - Rozszerzenia do przeglądarek Chrome, Edge, Brave, Firefox, Safari
 - Wsparcie dla 2FA
 - E2EE dla wszystkich danych
 - Integracja z proton mail i proton drive
2. Test podstawowych funkcji Proton Pass
 - 2.1. Metody zabezpieczenia dostępu do bazy haseł
 - Dostęp zabezpieczony jest hasłem głównym
 - Dodatkowo można ustawić 2fa
 - Hasło główne nie jest przechowywane na serwerze, jedynie jego hash jest porównywany lokalnie
 - Logowanie wymaga konta Proton
 - 2.2. Generacja haseł
 - Hasła do 64 znaków
 - uwzględnianie symboli, cyfr, wielkich i małych liter
 - Możliwość tworzenia łatwych do zapamiętania haseł (passphrases)
3. Zapisywanie haseł
 - Proton zapisuje hasła automatycznie przy nowym logowaniu, można grupować hasła w foldery
4. Uzupełnianie haseł na stronach
 - Rozszerzenia do przeglądarek wspierają autouzupełnianie loginów i haseł, rozpoznawanie pól formularzy działa na większości stron
 - Możliwość przypisania wielu loginów do tej samej domeny
5. Synchronizacja danych między urządzeniami:
 - Dane są synchronizowane w chmurze proton w czasie rzeczywistym wszystko przy zachowaniu E2EE
3. Co oznacza E2EE,
 - End to end encryption, oznacza że dane do chmury trafiają w formie zaszyfrowanej i są odszyfrowywane lokalnie
 - Proton pass wykorzystuje:
 - AES-256 – szyfrowanie danych
 - XChaCha20-Poly1305 – dodatkowo stosowany dla zapewnienia poufności i integralności
 - Argon2 – funkcja KDF używana do przetworzenia hasła głównego na klucz szyfrujący
 - Ed25519 – do weryfikacji integralności

Kluczowe cechy E2EE:

Brak dostępu pracowników proton do twoich haseł

Nawet gdy hasła zostaną wykradzione są bezużyteczne bez lokalnego klucza użytkownika

Ryzyka związane z menadżerami haseł online:

Keylogger

Słabe hasło główne

Ataki phishingowe

Ryzyko wycieku danych (jeśli nie ma E2EE)

Profil Zaufany, podpisy

poniedziałek, 16 czerwca 2025 23:27

XAdES - pozwala na podpisanie każdego rodzaju pliku i bazuje na języku XML

PAdES - pozwala na podpisanie tylko i wyłącznie pliku PDF

Warianty podpisu:

BES - podstawowy wariant podpisu

T - z dołączonym znacznikiem czasu

Typy podpisu:

Zewnętrzny - oddzielne pliki dla dokumentu i podpisu, przy weryfikacji należy dysponować wszystkimi plikami

Otoczony - struktura podpisu jest dołączona do dokumentu. Plik zawiera treść jak i podpis.

Otaczający (wewnętrzny) - struktura podpisu zawiera wewnątrz dokument który uległ podpisaniu. Przy weryfikacji wymagany jest jeden plik.

Podpis osobisty jest równoważny z podpisem zaufanym, z tym że podpisem osobistym możemy podpisywać umowy z firmą

Podpis osobisty składa minister na zlecenie osoby

Podpis kwalifikowany jest płatny i za 1-2 lat będzie za darmo

Wymaga też czytnika

Yubikey pozwala na zestoragowanie 32 certyfikatów

Lock code - specjalny kod którego nie da się zmienić

Yubikey gpg --card-status wymagany scdaemon

Można używać yubikey do uwerzytelnienia na linuxie za pomocą bibliotek libpam-u2f

Signal

wtorek, 17 czerwca 2025 05:59

End to End Encryption
Zero Knowledge

WhatsApp nie jest prywatny

Signal nie przechowuje żadnych wiadomości jedyne co można uzyskać to dane kiedy użytkownik założył konto i dane kiedy kiedy użytkownik był aktywny

Numer telefonu jest niezbędny do założenia konta

Register Lock - wymaga podania pinu przy rejestracji konta na nowym urządzeniu

Głównym urządzeniem sygnału jest telefon i jedynym, drugim urządzeniem jest komputer i aplikacja desktopowa

Na sygnale można ustawić automatyczne kasowanie danych

Każde z urządzeń ma swój klucz publiczny i prywatny

Signal jest wspierany przez służby i dozwolony do komunikacji

Backup zawiera klucze kryptograficzne czatów i nasze

Przy konfiguracji na nowym telefonie wyświetla się informacja o zmianie kluczy kryptograficznych

Najlepiej przenosić backupami

Można ustawić klawiaturę w trybie incognito

Nazwa użytkownika musi mieć dwie cyfry

Videorozmowy max 50 osób

Grupa max 1000 osób

Dane osobowe to komplet danych które określają konkretną osobę

XCA

wtorek, 17 czerwca 2025 00:04

PKI - public key infrastructure, jest to struktura do zarządzania pewną siecią certyfikatów lub kluczy publicznych

Wyróżniamy Root CA - czyli główny urząd certyfikacji

Oraz podurzędy np. Sub CA

Oraz End Entity - czyli użytkowników końcowych

Najpopularniejszym programem do obsługi tych funkcjonalności jest XCA, pozwala na tworzenie baz danych z kluczami i certyfikatami oraz list crt

Bazy danych mają format xdb. I są szyfrowane hasłem

Główny urząd certyfikacji jest self signed

W subject ustawiamy tożsamość

W extensions ustawiamy czy tworzymy CA czy END entity oraz date ważności

Weryfikacja certyfikatu polega na wykonaniu komendy

Openssl verify -CAfile ca.pem cert.pem

Gdzie ca.pem to urząd certyfikacji a cert.pem to certyfikat EE

Dla rozszerzanego łańcucha certyfikacji to będzie

Openssl verify -CAfile ca.pem -untrusted sub_ca.pem cert.pem

Jak skonfigurować serwer z certyfikatem

Po instalacji apache 2

```
sudo mkdir /etc/apache2/ssl
```

```
sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 \
```

```
-keyout /etc/apache2/ssl/server.key \
```

```
-out /etc/apache2/ssl/server.crt \
```

```
-subj "/C=PL/ST=mazowieckie/L=Warszawa/O=Test/OU=IT/CN=localhost"
```

Potem włączamy ssl i witrynę https

```
sudo a2enmod ssl
```

```
sudo a2ensite default-ssl
```

Zmieniamy ścieżki w /etc/apache2/sites-available/default-ssl.conf

```
Sudo nano /etc/apache2/sites-available/default-ssl.conf
```

I powinno być

```
SSLEngine on
```

```
SSLCertificateFile /etc/apache2/ssl/server.crt
```

```
SSLCertificateKeyFile /etc/apache2/ssl/server.key
```

Zrestartuj apache2

```
Sudo systemctl reload apache2
```